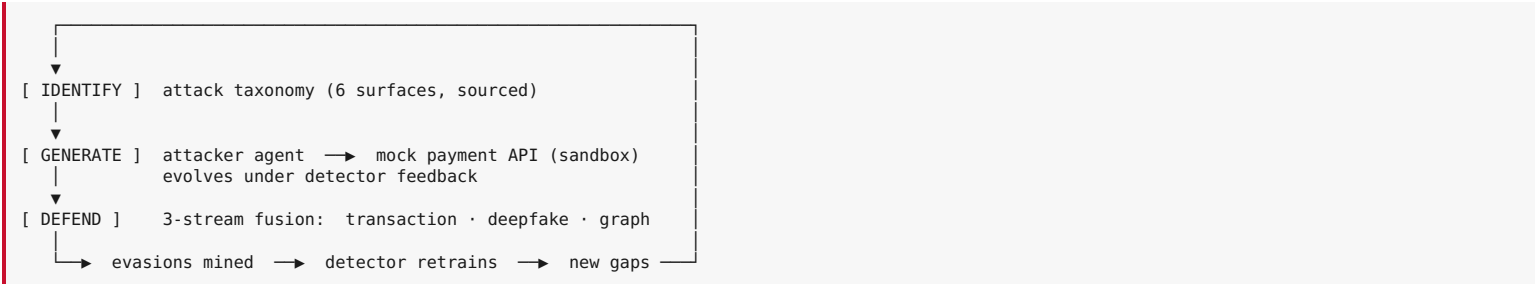


AI Defense Lab for Payment Security

Internal briefing — read before kickoff. Deadline **31 Aug 2026, 23:59 IST**. Results 5 Sep. Top teams present at GFF 2026, Jio World Centre, Mumbai (8–11 Sep). Team size 2–3. Budget: ~40–80 person-hours total.

1. What we are building

A **closed-loop red-team / blue-team system**: an attacker agent that generates GenAI-era payment fraud, a defense that detects it, and a feedback loop where each makes the other stronger. The loop is the product — not the classifier.



Four buildable components. Everything else is scope creep.

Component	What it does	Stack
C1. Attacker agent	Generates synthetic attack transactions/sequences, reads the detector's score as fitness, mutates until it evades. Produces the evasion curve that is our headline chart.	Evolutionary/genetic search over feature perturbations. Python, no RL for v1.
C2. Multimodal detector	Transaction-risk stream + social-engineering-channel stream (audio deepfake, face forgery) fused by a late-fusion meta-classifier into one risk score.	LightGBM/CatBoost + pretrained ASVspoof-style audio model + FF++ face model.
C3. Graph / mule layer	Money-flow graph features over mule topologies (fan-in/out, cycle, scatter-gather). Catches coordinated attacks tabular models miss.	NetworkX features first; GNN only if time allows. IBM AMLworld / AMLSim topologies.
C4. Agentic-payment demo	Minimal AP2-style mandate flow (Intent / Cart / Payment as signed credentials). Attacker forges or replays a mandate; verifier blocks it on signature, expiry, scope, or behavioural anomaly.	Signed JSON credentials against our <i>own</i> mock API. Never a live endpoint.

2. Why this shape wins

Judging is on five axes. Map every build decision to one of them or drop it.

Judging criterion	Median team's answer	Ours
Diversity of attacks identified	LLM-generated list of ~8 attack types	Six-surface taxonomy, every row tied to a real incident, protocol spec, or regulator source
Fidelity of simulation	Faker CSV, no fidelity evidence	TSTR (train-on-synthetic / test-on-real) + marginal & correlation similarity + a privacy check
Detection efficacy	ROC-AUC 0.98 on ULB, no temporal split	PR-AUC, recall@fixed-FPR, precision@k, calibration, temporal split, robustness under attack
Novelty	XGBoost + Streamlit	Closed loop with measurable co-evolution + deepfake fusion + agentic-mandate defense
Real-world feasibility	Not addressed	Latency budget, ISO 8583 / ISO 20022 message-level decisioning, integration points, explainability, governance

What we are deliberately not building. The predictable submission is: prompt an LLM for attack types → generate fake rows with Faker/CTGAN → train XGBoost on the ULB credit-card dataset → wrap in Streamlit. That dataset is from 2013, two days of European card traffic, PCA-anonymised into 28 opaque components. You cannot tell a payments judge a story about "realistic payment behaviour" using features named V1–V28. We use it as a sanity baseline only.

3. Our two unfair advantages

a. Deepfake detection is peer-reviewed in-house expertise

The attacks in scope are increasingly deepfake voice, video, and document — the Arup Hong Kong case (US\$25.6M across 15 transfers, Feb 2024) is the canonical example. Almost no team will fuse a real deepfake-detection stream with transaction risk. We can, and we can defend the design choices in Q&A. This is the centrepiece of the novelty slide.

b. Agentic commerce is the 2026 vein nobody has mined

Mastercard Agent Pay (Agentic Tokens, Verifiable Intent), Google AP2, Visa Trusted Agent Protocol, and the OpenAI/Stripe Agentic Commerce Protocol all shipped or expanded across 2025–26. They open genuinely new fraud modes: mandate forgery and replay, agent impersonation, over-authorisation / scope creep, indirect prompt injection via merchant pages, agent-to-agent collusion. Indirect prompt injection against shopping agents is documented in the wild (Unit 42, Zscaler ThreatLabz, Forcepoint, 2025–26), so this is demonstrable, not speculative. AP2 sample code is Apache-2.0 and runs without a live payment provider.

4. Attack taxonomy — the Identify pillar

Breadth *and* grounding are explicitly rewarded. Six surfaces; every row needs a citation.

Surface	Representative vectors
S1. GenAI social engineering	Deepfake CFO video calls; real-time voice-clone vishing; LLM-run romance / pig-butchering; BEC at scale; deepfake KYC and liveness bypass (note: <i>injection</i> attacks via virtual cameras are distinct from <i>presentation</i> attacks under ISO/IEC 30107-3); synthetic identity with generated documents and selfies
S2. India rails	UPI collect-request abuse (NPCI blocked P2P collect from 1 Oct 2025); QR manipulation / quishing; AutoPay and mandate abuse; UPI Lite and UPI Circle delegated payments; AePS and biometric spoofing; digital-arrest scams; mule networks. Defence context: CFCFRMS, 1930 helpline, RBI DPIP, MuleHunter.AI
S3. CNP / card-present	BIN enumeration; agent-automated card testing; 3-DS 2.x and OTP interception; SIM swap; adversary-in-the-middle kits defeating 2FA; wallet provisioning fraud; refund/chargeback and first-party fraud; Magecart skimming
S4. Agentic commerce	Mandate/intent forgery and replay; agent impersonation; scope creep and over-authorisation; indirect prompt injection via merchant pages; confused-deputy attacks; agent-to-agent collusion; agent traffic indistinguishable from human
S5. Adversarial ML	Black-box query evasion of the fraud scorer; poisoning of the retraining loop; concept-drift exploitation; model inversion; RL attackers that learn the decision boundary
S6. LLM scaling factors	Cheap multilingual scam localisation (material for India); automated OSINT victim profiling; scam-as-a-service tooling; synthetic document generation at volume

Sourcing discipline: vendor-reported percentages (iProov, Entrust, Mastercard uplift figures, Visa agent-traffic projections) get attributed to the named source in the deck, never stated as independent fact. No invented numbers. Any figure one of us cannot trace to a link gets deleted.

5. Data plan

Hard rule from the competition terms: **synthetic, anonymised, or authorised sample data only. No real cardholder data, no PII, no production payment data.** Every dataset below satisfies that. Record provenance in the repo README per dataset.

Dataset	Scale / imbalance	License	Use / gotcha
ULB credit-card	284,807 txns, 0.172% fraud	DbCL v1.0	Sanity baseline only; PCA features are unexplainable
IEEE-CIS	590,540 CNP txns, ~3.5% fraud, 431 features	Kaggle competition terms	Feature-rich CNP realism; check redistribution limits
PaySim	~6.36M mobile-money txns	CC BY-SA 4.0 (re-verify)	Best legitimate UPI-like proxy; balance columns leak the label — drop them
Sparkov / Shenoy	1,852,394 txns, ~0.52% fraud	CC0 1.0	Human-readable synthetic cards; Faker-simple distributions
IBM AMLworld	up to ~175M txns, 8 laundering patterns	CDLA-Sharing-1.0	Graph / mule layer, perfect labels; heavy preprocessing
Elliptic / Elliptic++	203,769 nodes, 234,355 edges	Research use	Temporal graph fraud; Bitcoin, not cards
ASVspoof, In-the-Wild	100k-680k+ utterances	Research-permissive	Audio-deepfake stream; check per-corpus terms
FaceForensics++ / DFDC	5,000 / 128,154 videos	Research EULA — must apply	Face-forgery stream; redistribution prohibited — do not commit data to the repo

No credible public UPI fraud dataset exists. The Kaggle "UPI transactions" sets are hobbyist synthetic and unvalidated against NPCI or RBI figures. Plan: use PaySim as the legitimate mobile-money base, generate our own UPI-flavoured synthetics on top, and *state this limitation openly in the deck*. Judges respect the disclosure; they will catch a bluff.

6. Metrics we report

Question	Metric
Does the defence work?	PR-AUC (primary, not ROC-AUC — imbalance makes ROC flattering), F1, calibration curve
Is it usable by a real fraud desk?	Recall at fixed FPR; precision@k under a realistic alert-review budget
What does it cost the business?	Money saved vs false-positive friction, at the chosen operating threshold
Are our attacks realistic?	TSTR (train synthetic → test real), marginal + correlation similarity, DCR / nearest-neighbour privacy check
Does the loop actually work?	Attack success rate per generation, time-to-evasion, detector robustness curve before vs after retraining
Could this run in live payments?	Measured p50/p99 inference latency, stated against an authorisation-time budget

TSTR trap to avoid: synthetic float columns vs real integer columns silently destroy predictive power. Enforce dtypes before evaluating.

7. Repository layout

ai-defense-lab/
├─ README.md
├─ ETHICS.md
├─ requirements.txt
├─ Makefile
├─ identify/
│ └─ taxonomy.yaml
├─ generate/
│ └─ synth/
│ └─ attacker/
│ └─ mock_api/
├─ defend/
│ └─ transaction/
│ └─ multimodal/
│ └─ graph/
│ └─ eval/
├─ loop/
├─ web/
└─ notebooks/

one-command run, data provenance, sandbox statement
scope, responsible disclosure, what we deliberately withheld
make data | make train | make loop | make demo
6 surfaces, every vector with source URL + rail + severity
SDV baseline; diffusion generator if time allows
evolutionary attacker, fitness = detector score
sandboxed payment API + AP2-style mandate flow
LightGBM/CatBoost + feature store
audio + face deepfake streams, late fusion
mule topology features
PR-AUC, recall@FPR, TSTR, latency harness
orchestration: attack → score → mine evasions → retrain
prototype UI
reproducible results, seeded

AI Defense Lab — Team Blue, Mastercard Innovation Challenge @ GFF 2026

2 / 3

Reproducibility is a scored criterion, not hygiene. Fixed seeds, pinned versions, one command to reproduce every number in the deck. If a chart cannot be regenerated from the repo, it does not go in the deck.

8. Deliverables

All three must be **submitted**, not left in draft, from the Writeups section before the deadline. Drafts are not judged.

Artifact	Must contain
Code repository	All three pillars, organised, documented, reproducible. README with setup, data provenance, and an explicit statement that all adversarial testing runs against our sandboxed mock API only.
Solution walkthrough (.pptx/.docx/.pdf)	(i) the novel attacks identified; (ii) how we generate and simulate them; (iii) detection and mitigation model with efficacy results; (iv) real-world feasibility in live payment environments. Add an ethics/responsible-AI slide even though it is not requested — it differentiates.
Web prototype	Presentable UI showing the closed loop live: attacker evolving, detector catching, a forged mandate being blocked, metrics updating. Record a fallback video — live demos fail.

9. Roles and 15-day plan

Days	Milestone	Detail
1-2	Identify locked	Taxonomy matrix complete and sourced. Deck skeleton. Scope frozen.
3-5	Generate v1	Synthetic transaction generator. Mock payment API + AP2-style mandate flow. Evolutionary attacker wired.
6-8	Defend v1	Transaction baseline + evaluation harness. Audio and face deepfake streams integrated. Late-fusion meta-classifier.
9-10	Loop closed	Attacker → detector → retrain running end to end. Evasion curve, time-to-evasion, robustness curve produced. Graph layer if on schedule.
11-12	Prototype	Web UI. Presentable, not elaborate.
13-14	Deck + rigour	TSTR numbers, latency measurement, feasibility slide, ethics slide. Repo reproducibility pass.
15	Buffer	Dry run, fallback video, submit early. Do not submit on the last evening.

Split

- **Lead:** closed loop, multimodal fusion, deck narrative and Q&A prep.
- **Eng 2:** data generation, detection models, graph layer, evaluation harness.
- **Eng 3 (if we are three):** web prototype, mock payment API, demo choreography. If we are two, the UI compresses to a single-page dashboard and the mock API moves to Eng 2.

10. Cut order

Agreed in advance so nobody negotiates under deadline pressure. Cut top-down:

1. RL attacker → scripted evolutionary attacker (already the v1 default; do not upgrade unless the loop works by day 9)
2. Graph / mule layer → transaction + multimodal only
3. Diffusion-based synthesis → CTGAN/TVAE only
4. Live interactive UI → recorded demo plus a clean notebook

Never cut: the closed loop, the PR-AUC / recall@FPR evaluation, reproducibility, and the ethics statement. Those four carry the score.

11. Hard rules — disqualification risk

- **Synthetic, anonymised, or authorised data only.** No real cardholder data, no PII, no production payment data. Ever.
- **No live systems.** Adversarial testing hits our sandboxed mock API and nothing else. No payment infrastructure, no third parties. Say this explicitly in the README and the deck.
- **No operational attack tooling published.** Redact scam scripts. Keep the attacker parameterised on synthetic features. We are demonstrating a stress-testing capability, not shipping a weapon.
- **Original work, honestly attributed.** Every forked dependency keeps its license and attribution (SDV, AMLSim, AP2 samples, ASVspoof baselines). Plagiarism or misrepresentation is disqualification at the sponsor's sole discretion.
- **No employer-confidential material.** Nothing from anyone's day job goes into the submission.
- **Do not commit licensed research datasets** (FF++, DFDC) into a public repo. Scripts that download them under the user's own agreement, only.

12. Decide on kickoff call

1. Two or three of us? Determines whether the graph layer survives.
2. Who owns the demo video and when it gets recorded (proposal: day 13, re-record day 15).
3. Repo host and whether it goes public before or after results.
4. Which single chart is the headline of the deck. Proposal: the evasion curve — attack success rate collapsing across retraining generations.

Prepared for internal team circulation. Figures attributed to vendors or regulators in the deck must carry their source; nothing in the final submission gets stated as fact without a traceable link.